

MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Evaluación de 9 Criterios para Todas las Métricas Mercury

INTRODUCCIÓN

Esta matriz valida todas las métricas propuestas en el informe Mercury contra los nueve criterios PRAGMATIC:

Código	Criterio	Definición	Escala
P	Predictivo	¿Predice resultados futuros?	1-5
R	Relevante	¿Importa a stakeholders?	1-5
A	Accionable	¿Podemos actuar sobre ella?	1-5
G	Genuino	¿Es a prueba de gaming?	1-5
M	Significativo	¿Es estadísticamente significativa?	1-5
Ac	Preciso	¿Es técnicamente precisa?	1-5
T	Oportuno	¿Se obtiene a tiempo?	1-5
I	Independiente	¿Está bajo nuestro control?	1-5
C	Rentable	¿Es costo-efectiva?	1-5

SECCIÓN 1: DOMINIO GOBERNANZA Y RIESGOS (GR)

Métrica GR-M1: Existencia de Metodología Formal de Riesgos (ISO 27005 / NIST SP 800-30)

Criterio	Puntuación	Justificación
P (Predictivo)	4	Estructura documentada predice madurez futura; pero toma tiempo ver resultados
R (Relevante)	5	Crítico para NIS2 Art. 20 y gobernanza regulatoria
A (Accionable)	5	Si falta → implementar; si existe → mejorar; si >2 años → actualizar
G (Genuino)	4	Difícil falsificar documentación, aunque auditoría requerida
M (Significativo)	4	Presencia/ausencia binaria, pero scope puede variar 0-100%
Ac (Preciso)	4	Verificable por auditor, pero subjetivo en "formalidad"
T (Oportuno)	3	Disponible si existe; pero actualización puede tardar meses
I (Independiente)	5	100% bajo control de organización
C (Rentable)	4	Costo implementación ~€15K; valor regulatorio €500K+

PRAGMATIC Score: $(4+5+5+4+4+4+3+5+4)/9 = 4.33$ ✓ EXCELENTE

Recomendación: Implementar. Métrica clave para foundation.

Métrica GR-M2: Cuantificación de Riesgos en Moneda (AVRQ/FAIR)

Criterio	Puntuación	Justificación
P (Predictivo)	5	Fuertemente predictivo de ROI; correlación directa con decisiones inversión
R (Relevante)	5	Crítico para CFO, Junta, reguladores (NIS2 Art. 20)
A (Accionable)	5	Disparador automático: AVRQ Score < 0.3 → Inversión recomendada
G (Genuino)	4	Depende de datos históricos; puede haber sesgo en assumptions
M (Significativo)	5	Cambios >€100K son detectables y significativos
Ac (Preciso)	3	AVRQ es propietario; Mercury AVRQ toma datos como entrada
T (Oportuno)	4	Cálculo toma días/semanas; pero puede automatizarse
I (Independiente)	3	Depende de threat intelligence externa (60% control)
C (Rentable)	4	Costo (€25K/año licencia) << Valor (ROI decisiones €2M+)

PRAGMATIC Score: $(5+5+5+4+5+3+4+3+4)/9 = 4.22$ ✓ EXCELENTE

Recomendación: Implementar. Requiere captura de datos iniciales.

Métrica GR-M3: Documentación y Comunicación de Políticas

Criterio	Puntuación	Justificación
P (Predictivo)	3	Medianamente predictivo; documentación ≠ compliance real
R (Relevante)	5	NIS2 requiere explícitamente comunicación
A (Accionable)	5	Si no documentado → documentar; si >2 años → revisar
G (Genuino)	3	Fácil falsificar documentación sin implementación real
M (Significativo)	3	Binaria (existe/no existe) aunque cobertura puede variar
Ac (Preciso)	5	Verificable por auditor; métrica clara
T (Oportuno)	5	Disponible inmediatamente
I (Independiente)	5	100% bajo control
C (Rentable)	5	Costo bajo (interno); valor alto (compliance)

PRAGMATIC Score: $(3+5+5+3+3+5+5+5+5)/9 = 4.33$ ✓ EXCELENTE

Recomendación: Implementar como métrica de baseline.

SECCIÓN 2: DOMINIO VULNERABILIDADES (VUL)

Métrica VUL-M1: Frecuencia de Escaneo de Vulnerabilidades

Criterio	Puntuación	Justificación
P (Predictivo)	2	Débilmente predictivo; frecuencia no garantiza detección
R (Relevante)	3	Importa a técnicos, pero no a ejecutivos
A (Accionable)	4	Si semanal → evaluar ROI
G (Genuino)	4	Difícil falsificar si automatizado; vulnerable si manual
M (Significativo)	2	Trivial; cualquier scanning es "activo"
Ac (Preciso)	5	Log automático de escaneos; muy preciso
T (Oportuno)	5	Disponible en tiempo real
I (Independiente)	5	100% control
C (Rentable)	5	Bajo costo (herramientas existing)

PRAGMATIC Score: $(2+3+4+4+2+5+5+5+5)/9 = 3.89$ ✓ BUENO

Recomendación: Implementar; pero combinar con otras métricas VUL.

Métrica VUL-M2: Tasa de Detección y Remediación (MTTR) de Vulnerabilidades

Criterio	Puntuación	Justificación
P (Predictivo)	5	Altamente predictivo; MTTR correlaciona directamente con breach probability
R (Relevante)	5	Crítico para NIS2 Art. 21 (<14 días requerido)
A (Accionable)	5	Dispara escalada si MTTR críticos >7 días
G (Genuino)	5	Difícil gaming; requiere remediación real
M (Significativo)	5	Cambios de 1 día son detectables y significativos
Ac (Preciso)	4	Automático si integrado ticketing system; some manual validation
T (Oportuno)	5	Disponible diariamente; reporte automático
I (Independiente)	3	60% control (depende vendor patches)
C (Rentable)	5	Bajo costo; alto valor

PRAGMATIC Score: $(5+5+5+5+5+4+5+3+5)/9 = 4.67 \checkmark$ EXCEPCIONAL

Recomendación: Implementar como métrica primaria. Crítica para NIS2.

Métrica VUL-M3: Cobertura de Escaneo vs. Activos

Criterio	Puntuación	Justificación
P (Predictivo)	4	Predice brechas; activos no escaneados = riesgo
R (Relevante)	5	Importante para postura completa
A (Accionable)	5	Si cobertura <90% → ampliar escaneo
G (Genuino)	3	Fácil gaming: reportar activos inventario sin scan actual
M (Significativo)	4	Cambios >5% detectables
Ac (Preciso)	4	Requiere CMDB actualizado (vulnerabilidad)
T (Oportuno)	4	Disponible mensualmente; puede automatizarse
I (Independiente)	4	70% control (depende CMDB precision)
C (Rentable)	5	Bajo costo

PRAGMATIC Score: $(4+5+5+3+4+4+4+4+5)/9 = 4.22$ ✓ EXCELENTE

Recomendación: Implementar; requiere CMDB robusto.

SECCIÓN 3: DOMINIO SIEM E INCIDENTES (SIEM)

Métrica SIEM-M1: Tasa de Falsos Positivos (FPR)

Criterio	Puntuación	Justificación
P (Predictivo)	5	Predice ineffectividad real de alertas; alto FPR = ceguera
R (Relevante)	5	Crítico para SOC; directamente afecta eficacia
A (Accionable)	5	Si FPR >20% – tuning urgente
G (Genuino)	4	Puede manipularse reduciendo sensibilidad; auditable
M (Significativo)	5	Cambios >1% detectables; estadísticamente significativos
Ac (Preciso)	4	Requiere manual review de alertas; error ~10%
T (Oportuno)	5	Disponible semanalmente; reporte automático
I (Independiente)	5	Completamente bajo nuestro control (tuning SIEM)
C (Rentable)	5	Bajo costo; alto impacto

PRAGMATIC Score: $(5+5+5+4+5+4+5+5+5)/9 = 4.78$ ✓ EXCEPCIONAL

Recomendación: Implementar como métrica primaria. Crítica para SOC.

Métrica SIEM-M2: Mean Time To Detect (MTTD)

Criterio	Puntuación	Justificación
P (Predictivo)	5	Altamente predictivo; MTTD < daño = efectivo
R (Relevante)	5	NIS2 requiere detección rápida (implied <24h)
A (Accionable)	5	Si MTTD >4h críticas → escalada automática
G (Genuino)	5	A prueba de gaming; timestamp objetivo
M (Significativo)	5	Cambios <1h detectables; altamente significativos
Ac (Preciso)	5	Automático SIEM; precisión <1 minuto
T (Oportuno)	5	Disponible en tiempo real
I (Independiente)	5	100% bajo control
C (Rentable)	5	Bajo costo; crítico valor

PRAGMATIC Score: $(5+5+5+5+5+5+5+5+5)/9 = 5.0$ ★ PERFECTO

Recomendación: Implementar como métrica primaria ABSOLUTA.

Métrica SIEM-M3: Automatización de Respuesta (SOAR)

Criterio	Puntuación	Justificación
P (Predictivo)	4	Predice velocidad respuesta; pero no necesariamente efectividad
R (Relevante)	4	Importa a SOC, CTO; directamente afecta MTTR
A (Accionable)	5	Si <30% automatizado → implementar SOAR
G (Genuino)	3	Fácil gaming: contar "automático" lo que no lo es
M (Significativo)	4	Cambios >10% detectables
Ac (Preciso)	4	Requiere auditoría de playbooks; some subjetividad
T (Oportuno)	5	Disponible continuamente
I (Independiente)	4	75% control (depende herramientas integración)
C (Rentable)	3	SOAR caro (€100K+ setup); valor alto pero ROI 2+ años

PRAGMATIC Score: $(4+4+5+3+4+4+5+4+3)/9 = 4.0$ ✓ EXCELENTE

Recomendación: Implementar; priorizar después de MTTD/FPR.

SECCIÓN 4: DOMINIO CAPACITACIÓN (CAP)

Métrica CAP-M1: Cobertura de Capacitación (% de empleados)

Criterio	Puntuación	Justificación
P (Predictivo)	2	Débil predictor; cobertura ≠ retención ≠ seguridad
R (Relevante)	4	NIS2 requiere, pero es métrica de input, no outcome
A (Accionable)	4	Si <90% → escalada; pero acción es administrativa
G (Genuino)	2	Fácil gaming: reportar participación sin comprensión
M (Significativo)	2	Métrica de actividad, no impacto
Ac (Preciso)	5	Verificable en registros LMS
T (Oportuno)	5	Disponible en tiempo real
I (Independiente)	5	100% control
C (Rentable)	5	Bajo costo

PRAGMATIC Score: $(2+4+4+2+2+5+5+5+5)/9 = 3.78$ ✓ BUENO

Recomendación: Implementar; pero complementar con métricas outcome (CAP-M2, M3).

Métrica CAP-M2: Tasa de Clicks en Phishing Simulado

Criterio	Puntuación	Justificación
P (Predictivo)	5	Altamente predictivo de riesgo real; correlación directa con breach por error humano
R (Relevante)	5	Crítico para seguridad operacional; importa a ejecutivos
A (Accionable)	5	Si click rate >10% → capac inmediata; <5% → mantener
G (Genuino)	4	A prueba de gaming si simulaciones varían; vulnerable si repetitivas
M (Significativo)	5	Cambios >1% detectables; estadísticamente significativos
Ac (Preciso)	5	Automático plataforma phishing; error <1%
T (Oportuno)	5	Disponible post-simulación (horas)
I (Independiente)	5	100% control
C (Rentable)	5	Bajo costo; impacto alto

PRAGMATIC Score: $(5+5+5+4+5+5+5+5+5)/9 = 4.89$ ✓ EXCEPCIONAL

Recomendación: Implementar como métrica primaria para CAP.

Métrica CAP-M3: Tasa de Reporte de Amenazas

Criterio	Puntuación	Justificación
P (Predictivo)	4	Predice vigilancia de empleados; detección temprana
R (Relevante)	4	Importante operacionalmente; menos crítico regulatoriamente
A (Accionable)	5	Si <20% emails maliciosos reportados → mejorar incentivos
G (Genuino)	4	Medianamente a prueba de gaming; puede incentivar false reports
M (Significativo)	4	Cambios >5% detectables
Ac (Preciso)	4	Automático conteo; pero clasificación requerida
T (Oportuno)	5	Disponible diariamente
I (Independiente)	4	75% control (depende participación empleados)
C (Rentable)	5	Bajo costo; alto valor

PRAGMATIC Score: $(4+4+5+4+4+4+5+4+5)/9 = 4.33 \checkmark$ EXCELENTE

Recomendación: Implementar como métrica secundaria.

SECCIÓN 5: DOMINIO CUMPLIMIENTO NORMATIVO (NORM)

Métrica NORM-M1: Conformidad NIS2 (% Medidas Implementadas)

Criterio	Puntuación	Justificación
P (Predictivo)	5	Predice postura auditoría regulatoria; directo a sanciones
R (Relevante)	5	Crítico para regulador CNCS; obligatorio antes Q1 2026
A (Accionable)	5	Si <80% → plan escalada; si 100% → certificación
G (Genuino)	4	Auditable; pero definición "implementado" puede variar
M (Significativo)	5	Cambios >5% detectables; significativos
Ac (Preciso)	4	Requiere auditor externo para validar
T (Oportuno)	3	Disponible trimestral; puede retrasarse
I (Independiente)	5	100% bajo control
C (Rentable)	3	Auditoría externa costosa (€20-50K); pero valor regulatorio >>

PRAGMATIC Score: $(5+5+5+4+5+4+3+5+3)/9 = 4.33 \checkmark$ EXCELENTE

Recomendación: Implementar como métrica crítica para governance. Usar auditor externo trimestral.

Métrica NORM-M2: Certificación ISO 27001

Criterio	Puntuación	Justificación
P (Predictivo)	4	Predice madurez; pero es snapshot, no continuo
R (Relevante)	4	Importante para clientes B2B; no obligatorio
A (Accionable)	3	Si no certificado → planificar; si certificado → mantener
G (Genuino)	5	Tercera parte audita; a prueba de gaming
M (Significativo)	2	Binaria (certificado/no); no detecta madurez
Ac (Preciso)	5	Verificable por DNV, TÜV, etc.
T (Oportuno)	1	Triennial; meses de retraso post-auditoría
I (Independiente)	5	100% control
C (Rentable)	2	Caro (€30-80K); valor principalmente reputacional

PRAGMATIC Score: $(4+4+3+5+2+5+1+5+2)/9 = 3.44$ ⚠️ ACCEPTABLE

Recomendación: Implementar; pero como métrica secundaria. Combinar con auditoría interna mensual.

SECCIÓN 6: DOMINIO CONTINUIDAD (CONT)

Métrica CONT-M1: RTO/RPO Documentados

Criterio	Puntuación	Justificación
P (Predictivo)	4	Predice si organización puede recuperarse; pero solo si testeado
R (Relevante)	5	NIS2 requiere; crítico para continuidad
A (Accionable)	5	Si no documentado → crear; si >2 años → revisar
G (Genuino)	3	Fácil falsificar; requiere test regular
M (Significativo)	3	Documentación existe/no existe; binaria
Ac (Preciso)	4	Verificable; pero interpretación puede variar
T (Oportuno)	3	Disponible si existe; reviews lentas
I (Independiente)	5	100% control
C (Rentable)	5	Bajo costo

PRAGMATIC Score: $(4+5+5+3+3+4+3+5+5)/9 = 4.11$ ✓ EXCELENTE

Recomendación: Implementar; complementar con testing regular (anual mínimo).

Métrica CONT-M2: Frecuencia de Testing DR

Criterio	Puntuación	Justificación
P (Predictivo)	5	Altamente predictivo; testing anual = confianza en recuperación
R (Relevante)	5	Crítico para NIS2 y operaciones
A (Accionable)	5	Si <anual → programar; si falla → analizar/mejorar
G (Genuino)	5	A prueba de gaming; test es objetivo
M (Significativo)	4	Cambios >10% en métricas detectables
Ac (Preciso)	5	Verificable; metrics de test claros
T (Oportuno)	4	Post-test disponible (horas)
I (Independiente)	4	80% control (depende vendor sistemas)
C (Rentable)	3	Testing costoso (€50-100K/test); pero valor >>

PRAGMATIC Score: $(5+5+5+5+4+5+4+4+3)/9 = 4.44$ ✓ EXCELENTE

Recomendación: Implementar. Crítica para validación.

SECCIÓN 7: MATRIZ SUMARIA DE TODOS LOS DOMINIOS

#	Métrica	Dom inio	P	R	A	G	M	Ac	T	I	C	Scor e	Reco men daci ón
1	Met odol ogía Ries gos	GR	4	5	5	4	4	4	3	5	4	4.33	✓ Impl eme ntar
2	AVR Q Cua ntifi caci ón	GR	5	5	5	4	5	3	4	3	4	4.22	✓ Impl eme ntar
3	Polít icas Doc ume ntad as	GR	3	5	5	3	3	5	5	5	5	4.33	✓ Impl eme ntar
4	Frec uenc ia Esca neo VUL	VUL	2	3	4	4	2	5	5	5	5	3.89	✓ Impl eme ntar
5	MTT R Vuln erab ilida des	VUL	5	5	5	5	5	4	5	3	5	4.67	★ Prim aria
6	Cobe rtur a Esca neo	VUL	4	5	5	3	4	4	4	4	5	4.22	✓ Impl eme ntar
7	FPR SIE M	SIE M	5	5	5	4	5	4	5	5	5	4.78	★ Prim aria

8	MTTD	SIE M	5	5	5	5	5	5	5	5	5	5.0	★ ★ PER FEC TO
9	Automatización SOA R	SIE M	4	4	5	3	4	4	5	4	3	4.0	✓ Impl eme ntar
10	Cobertura Capacitación	CAP	2	4	4	2	2	5	5	5	5	3.78	✓ Impl eme ntar (co mple men tar)
11	Click Rate Phishing	CAP	5	5	5	4	5	5	5	5	5	4.89	★ Prim aria
12	Tasa Reporte Amenazas	CAP	4	4	5	4	4	4	5	4	5	4.33	✓ Impl eme ntar
13	Conformidad NIS2	NOR M	5	5	5	4	5	4	3	5	3	4.33	★ Críti ca
14	Certificación ISO 27001	NOR M	4	4	3	5	2	5	1	5	2	3.44	⚠ Acep table
15	RTO / RPO Documento	CON T	4	5	5	3	3	4	3	5	5	4.11	✓ Impl eme ntar

16	Testi ng DR Frec uenc ia	CON T	5	5	5	5	4	5	4	4	3	4.44	✓ Impl eme ntar
----	---	----------	---	---	---	---	---	---	---	---	---	------	--------------------------

SECCIÓN 8: ANÁLISIS DE RESULTADOS

8.1 Métrica Perfecta (Score 5.0)

MTTD (Mean Time To Detect)

- Todos los criterios en 5 excepto independencia (5) y algunos detalles
- Implementar como métrica primaria ABSOLUTA para SIEM

8.2 Métricas Excepcionales (Score ≥ 4.8)

Métrica	Score	Razón
Click Rate Phishing	4.89	Altamente predictivo, accionable, preciso
FPR SIEM	4.78	Control total, disponibilidad, predictor fuerte

Acción: Implementar como métricas secundarias primarias.

8.3 Métricas Excelentes (Score 4.0-4.8)

- Mayoría de métricas propuestas caen aquí
- Acción: Implementar con priorización según dominio criticidad
- Métricas VUL, GR, NORM son críticas
- Métricas CONT, CAP son importantes pero menos urgentes

8.4 Métricas Aceptables (Score 3.5-4.0)

Métrica	Score	Mejora Recomendada
ISO 27001 Certificación	3.44	Complementar con auditoría interna mensual
Cobertura Capacitación	3.78	Complementar con click rate phishing

Acción: Implementar; pero refinar diseño para mejorar score.

8.5 Métricas Débiles (Score < 3.5)

Ninguna en matriz propuesta.

Si hubiera: Reconsiderar o rediseñar.

SECCIÓN 9: RECOMENDACIONES DE PRIORIZACIÓN

Implementación Phase 1 (Q1 2026) - CRÍTICAS

Métricas Score ≥ 4.5 + Relevancia NIS2 = Implementar YA

1. MTTD (5.0) – Absoluta prioridad
2. FPR SIEM (4.78) – Soporte a MTTD
3. Click Rate Phishing (4.89) – Riesgo humano
4. Conformidad NIS2 (4.33) – Regulatorio
5. MTTR Vulnerabilidades (4.67) – NIS2 Art. 21

Inversión total: €150-200K

Timeline: 4-6 semanas

Implementación Phase 2 (Q2-Q3 2026) - IMPORTANTES

Métricas 4.0-4.5 Score

6. AVRQ Cuantificación (4.22)
7. Cobertura Escaneo (4.22)
8. Tasa Reporte Amenazas (4.33)
9. Testing DR Frecuencia (4.44)
10. Automatización SOAR (4.0)

Timeline: 12-16 semanas

Implementación Phase 3 (Q4 2026+) - COMPLEMENTARIAS

Métricas 3.5-4.0 Score + mejoras de Phase 1

11. ISO 27001 Certificación (3.44) + auditoría interna
12. Cobertura Capacitación (3.78) + complementos

CONCLUSIÓN

La matriz PRAGMATIC demuestra que:

- ✓ **5 métricas son excepcionales** (Score ≥ 4.8): Implementar inmediatamente
- ✓ **11 métricas son excelentes** (Score 4.0-4.8): Implementar en fases
- ⚠ **2 métricas son aceptables** (Score 3.5-4.0): Implementar + refinar

Métrica más crítica: MTTD (5.0) – Prioridad absoluta

Fin de Matriz PRAGMATIC

Versión 2.0 | Enero 2026